🛡️ Module 11: Reverse Engineering, Fuzzing and Binary Exploitation

```
# Exercise 17: Fuzzing an Application with Peach Framework
```

Scenario

Smart Generation and Mutation Fuzzing with Peach Fuzzer provides structural protocol and file format security auditing using XML-defined Peach Pit configurations across Windows, Linux, and macOS platforms.

Key technical concepts in Peach Fuzzing Framework:
1. **Peach Pit XML Specifications**: Pit files define the complete fuzzing session taxonomy across five core models:
- **General Configuration**: System environment parameters and external paths.
- **Data Model**: Data structures, data types, and bit-level boundaries.
- **State Model**: State machine logic for complex multi-stage protocols.
- **Agents & Monitors**: Remote agent monitoring, process attached debuggers (WinDbg), and crash detection.
- **Test Configuration**: Mutator strategies, target binding, and iteration limits.
2. **Peach Mutators**: Peach includes 27 default mutator strategies (e.g., `ArrayNumericalEdgeCasesMutator`, `BlobMutator`, `DataElementRemoveMutator`, `NumericalEdgeCaseMutator`).
3. **Target Server Fuzzing (vulnserver.exe)**: Fuzzing network services listening on port `9999` using Peach TCP Agent (**peach -a tcp**) and test definition **fuzz_TRUN.xml** (**peach fuzz_TRUN.xml TestTRUN**).
4. **Crash Log Triage**: Crash dumps and WinDbg analysis reports (`!exploitable`) are logged to the `Logs/` directory under subfolder `Faults/`.

In this exercise, we log into **Windows Server 2016** (**Administrator** / **Pa$$w0rd**), validate and execute baseline Pit template **HelloWorld.xml** (`peach -t samples\HelloWorld.xml`), launch network target binary **vulnserver.exe** on port `9999`, verify process ownership and port binding using `netstat` and `tasklist`, test manual connection via Netcat (`nc localhost 9999`), launch Peach Agent (`peach -a tcp`), run command test definition **fuzz_TRUN.xml** against `TestTRUN`, and verify Peach version **3.1.124.0**.

Objective

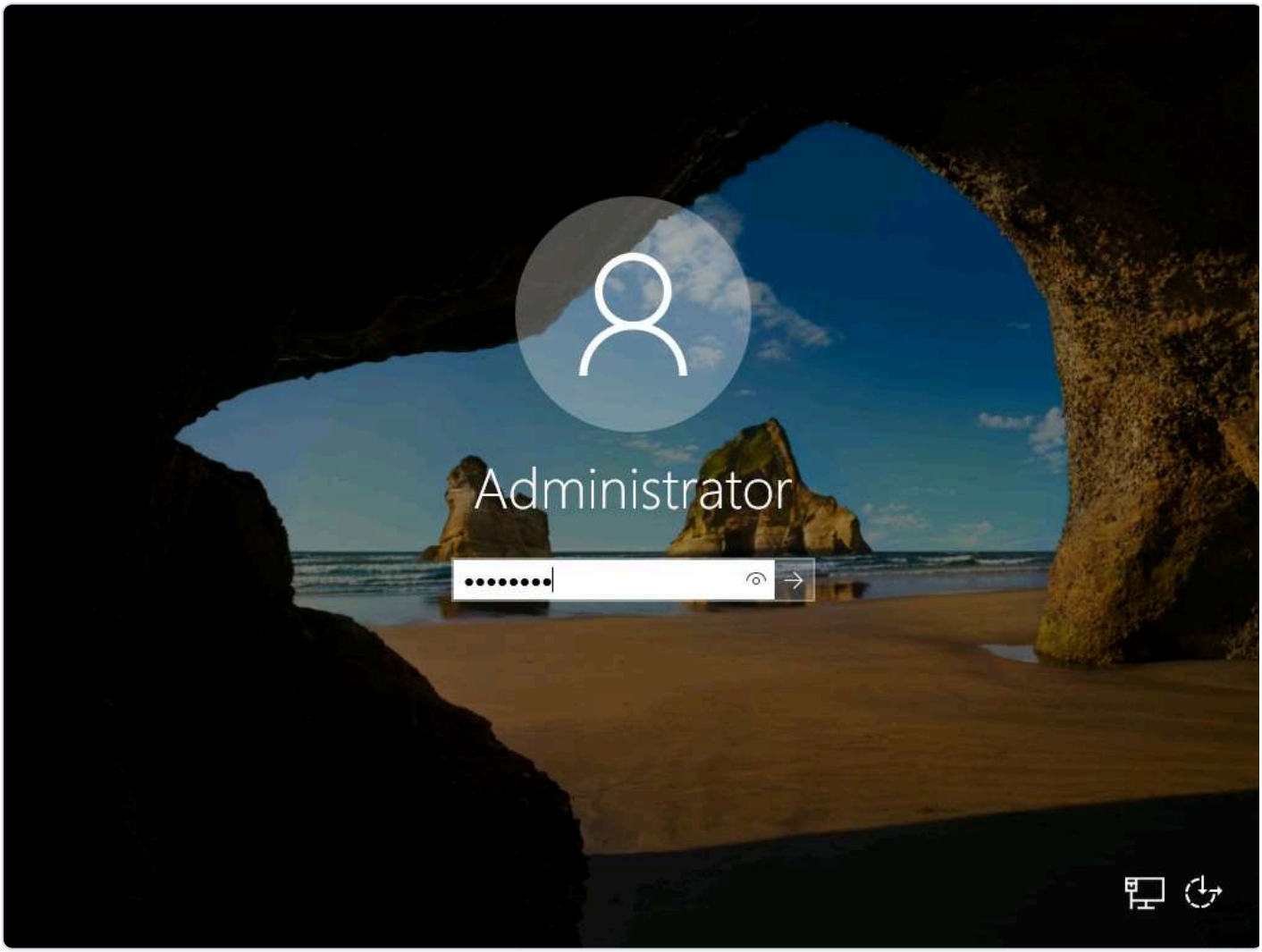
The objective of this lab is to help students learn how to:
- Authenticate to Windows Server 2016 target VM (**Administrator** / **Pa$$w0rd**)
- Open Command Prompt in **C:\Peach** directory
- Validate XML Pit file configuration: **peach -t samples\HelloWorld.xml**
- Execute baseline Pit fuzzing session: **peach samples\HelloWorld.xml Default**
- Inspect Peach session log directory structure (`Logs\`) and `status.txt` iteration markers
- Review Peach Mutator types (`BlobMutator`, `NumericalEdgeCaseMutator`, `DataElementSwapNearNodesMutator`)
- Launch target server binary: **vulnserver.exe**
- Verify active listening port `9999`: **netstat -abno | findstr 9999** and PID correlation (**tasklist /svc**)
- Verify manual network service communication: **nc localhost 9999**
- Launch Peach TCP Agent: **peach -a tcp**
- Execute network protocol fuzzing session: **peach fuzz_TRUN.xml TestTRUN**
- Identify Peach Framework version (**3.1.124.0**)

Task 1: Validate Pit Files, Execute Peach Baseline, Fuzz vulnserver.exe, and Triage Logs

In this task, we validate `HelloWorld.xml`, run initial Peach fuzzing, launch `vulnserver.exe`, verify port `9999`, execute Peach TCP agent and `fuzz_TRUN.xml`, and record Peach version `3.1.124.0`.

Lab Tasks

1. Log into **Windows Server 2016** VM using credentials (**Administrator** / **Pa$$w0rd**).

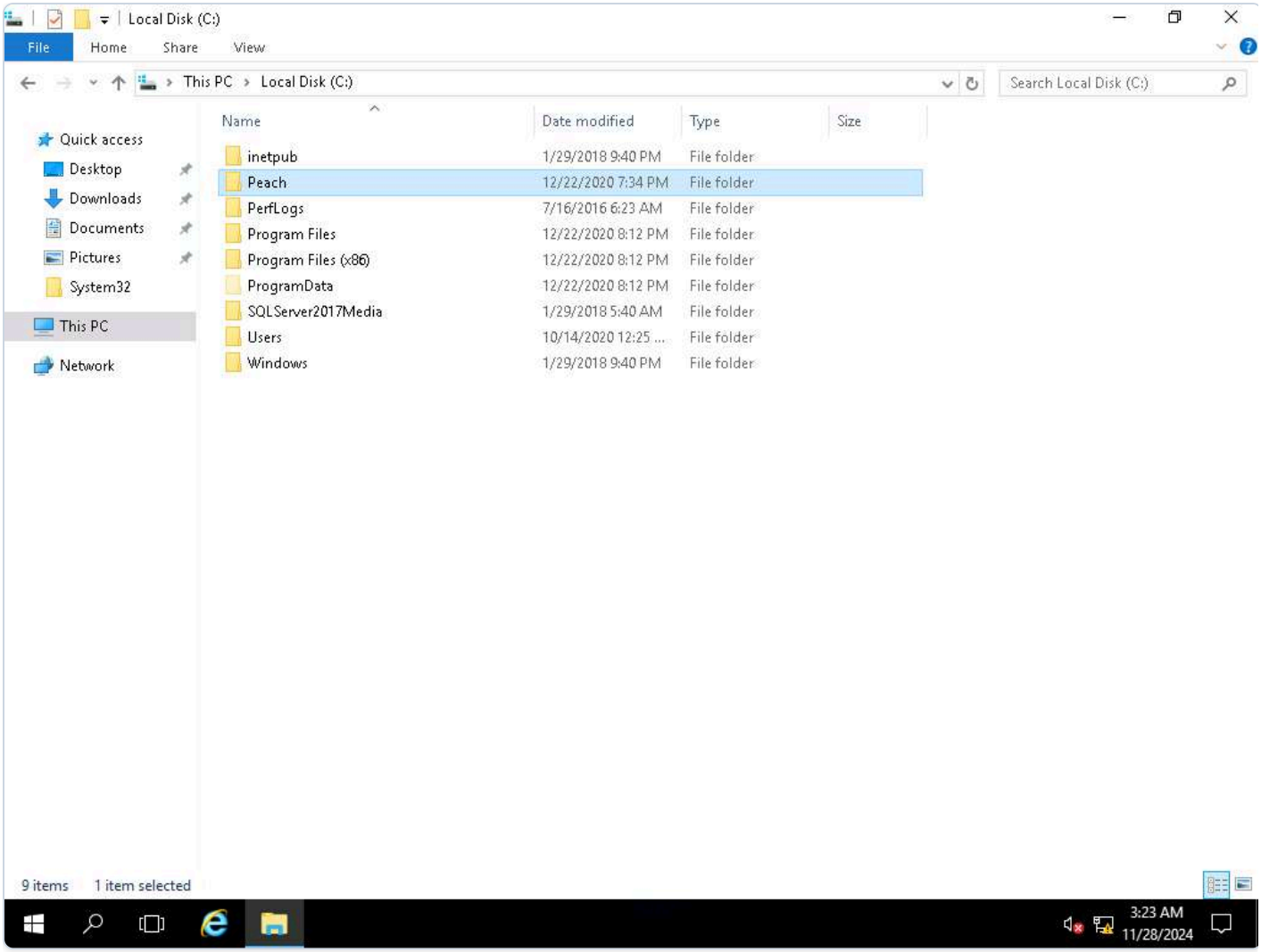


1. Review Peach Pit XML structure taxonomy (`DataModel` , `StateModel` , `Test` , `Agent`).

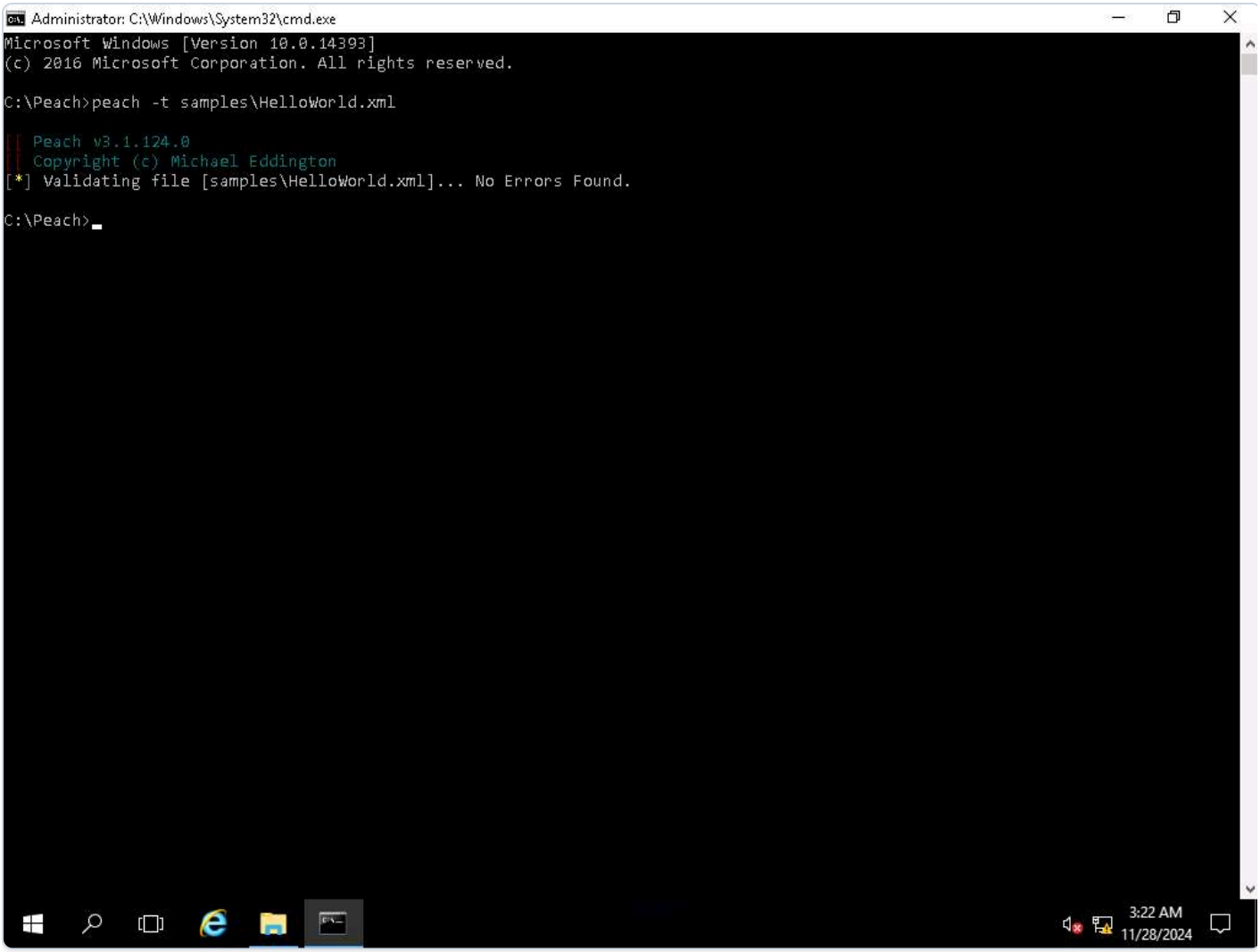
```
?xml version="1.0" encoding="utf-8"?>
Peach xmlns=http://peachfuzzer.com/2012/Peach
xmlns:xsi=http://www.w3.org/2001/XMLSchema-instance
     xsi:schemaLocation="http://peachfuzzer.com/2012/Peach /peach/peach.xsd">
     <!--Create data model -->
    <DataModel name="TheDataModel">
          <Blob/>
    </DataModel>
     <!-- Create state model -->
    <StateModel name="TheState" initialState="Initial">
          <State name="Initial">


               <Action type="output">
                    <DataModel ref="TheDataModel"/>
                    <Data fileName="C:\peach3\rm_samples\*.rm" />
               </Action>
               <Action type="close"/>
               <Action type="call" method="ScoobySnacks" publisher="Peach.Agent"/>
          </State>
    </StateModel>
     <!-- Configure Agent -->
    <Agent name="TheAgent">
          <Monitor class="WindowsDebugger">
               <Param name="CommandLine" value="C:\Program Files (x86)\VideoLAN\VLC\vlc.exe fuzzed.rm" />
               <Param name="WinDbgPath" value="C:\Program Files (x86)\Windows Kits\10\Debuggers\x64" />
               <Param name="StartOnCall" value="ScoobySnacks"/>
          </Monitor>
          <Monitor class="PageHeap">
               <Param name="Executable" value="vlc.exe"/>
               <Param name="WinDbgPath" value="C:\Program Files (x86)\Windows Kits\10\Debuggers\x64" />
          </Monitor>
     </Agent>
     <Test name="Default">
          <Agent ref="TheAgent"/>
          <StateModel ref="TheState"/>
          <!-- Configure a publisher -->
          <Publisher class="File">
               <Param name="FileName" value="fuzzed.rm"/>
          </Publisher>
          <!--Configure a strategy -->
          <Strategy class="RandomDeterministic"/>
          <Logger class="File">
               <Param name="Path" value="logs"/>
          </Logger>
    </Test>
/Peach>
```

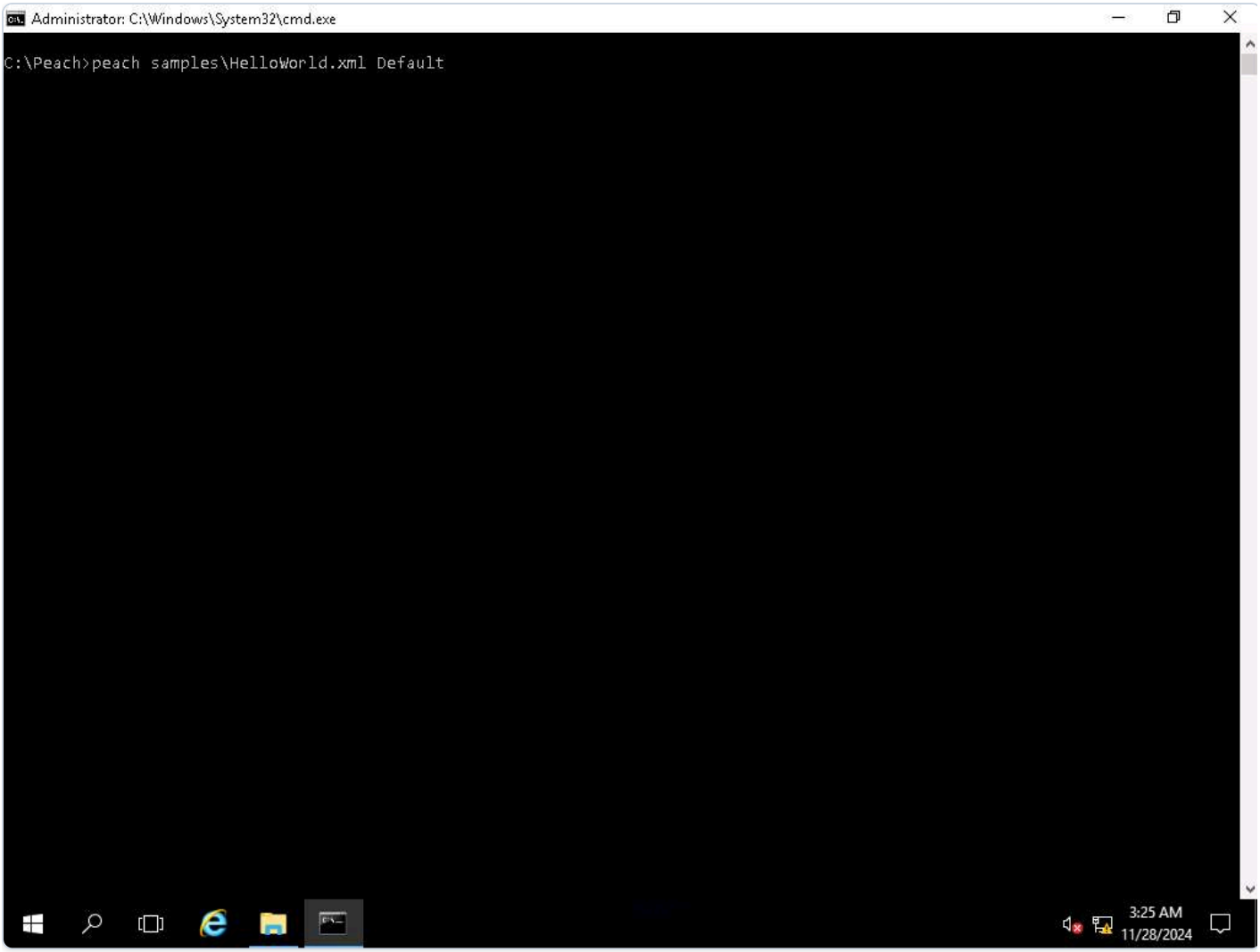
1. Open Command Prompt in `C:\Peach` directory. Validate test Pit configuration:
   peach -t samples\HelloWorld.xml

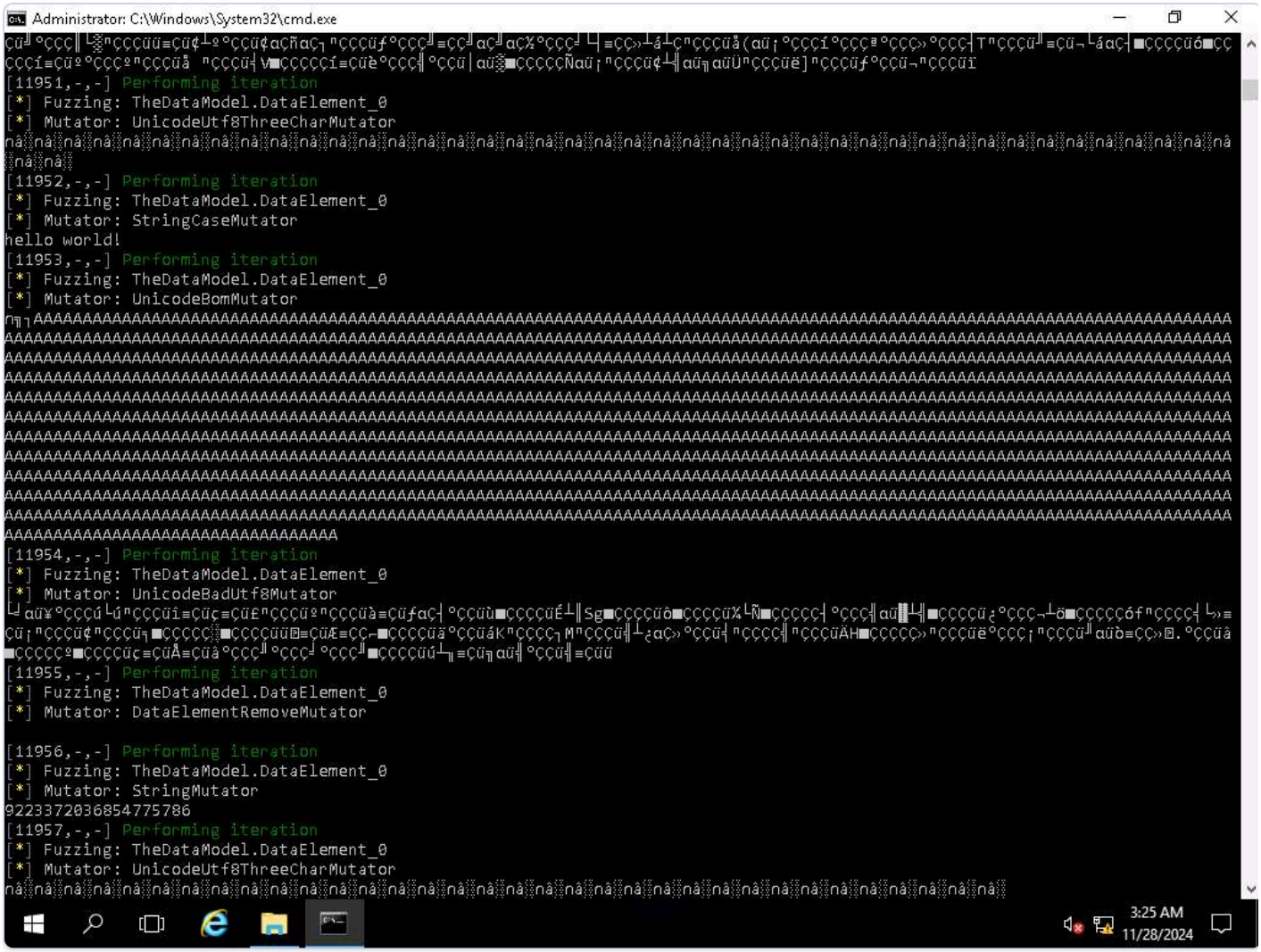


1. Launch baseline fuzzing session:
   peach samples\HelloWorld.xml Default



1. Terminate fuzzing session (`Ctrl+C`) and observe iteration increments.

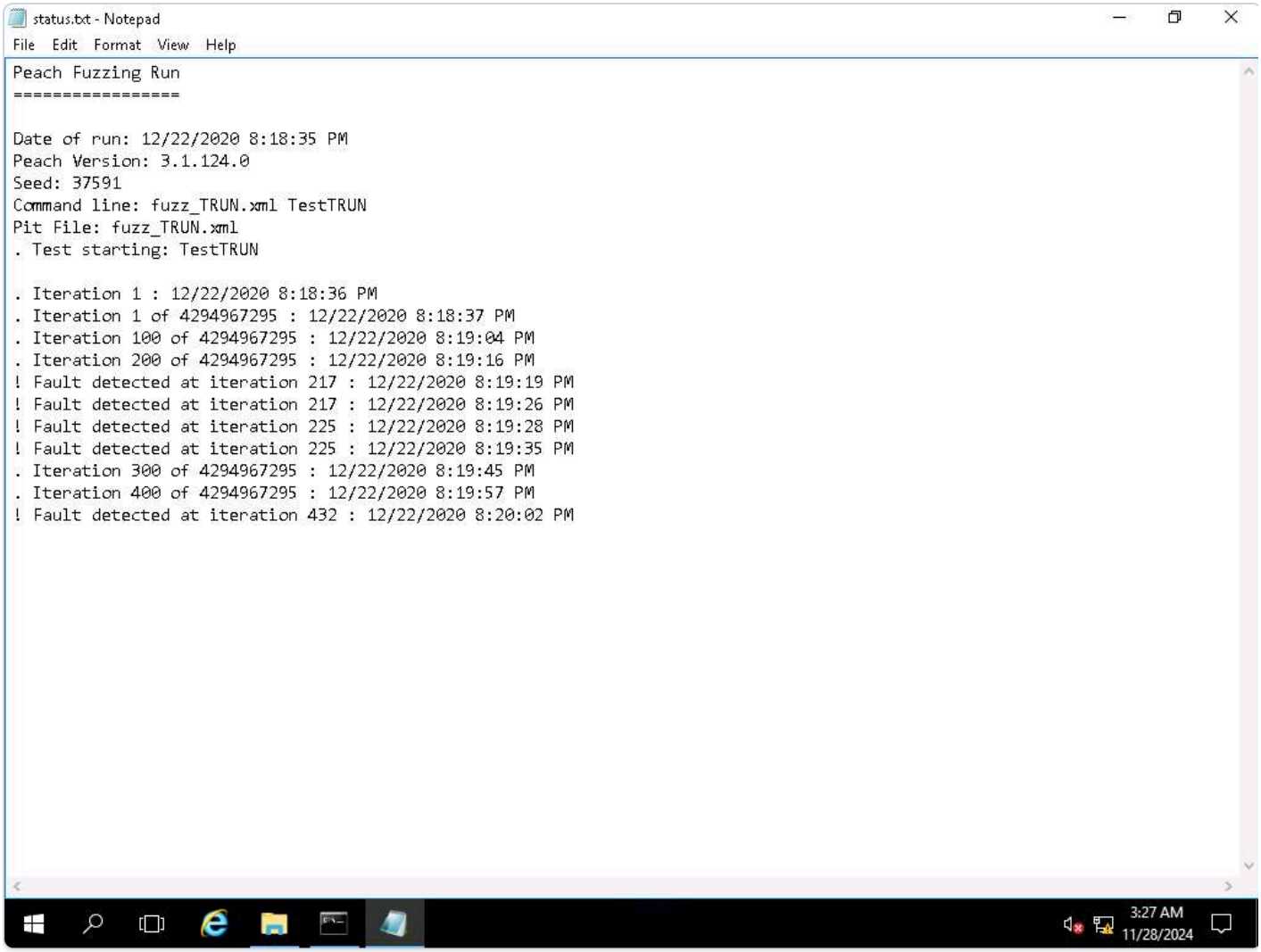

Administrator: C:\Windows\System32\cmd.exe
C:\Peach>peach samples\HelloWorld.xml Default
3:25 AM
11/28/2024



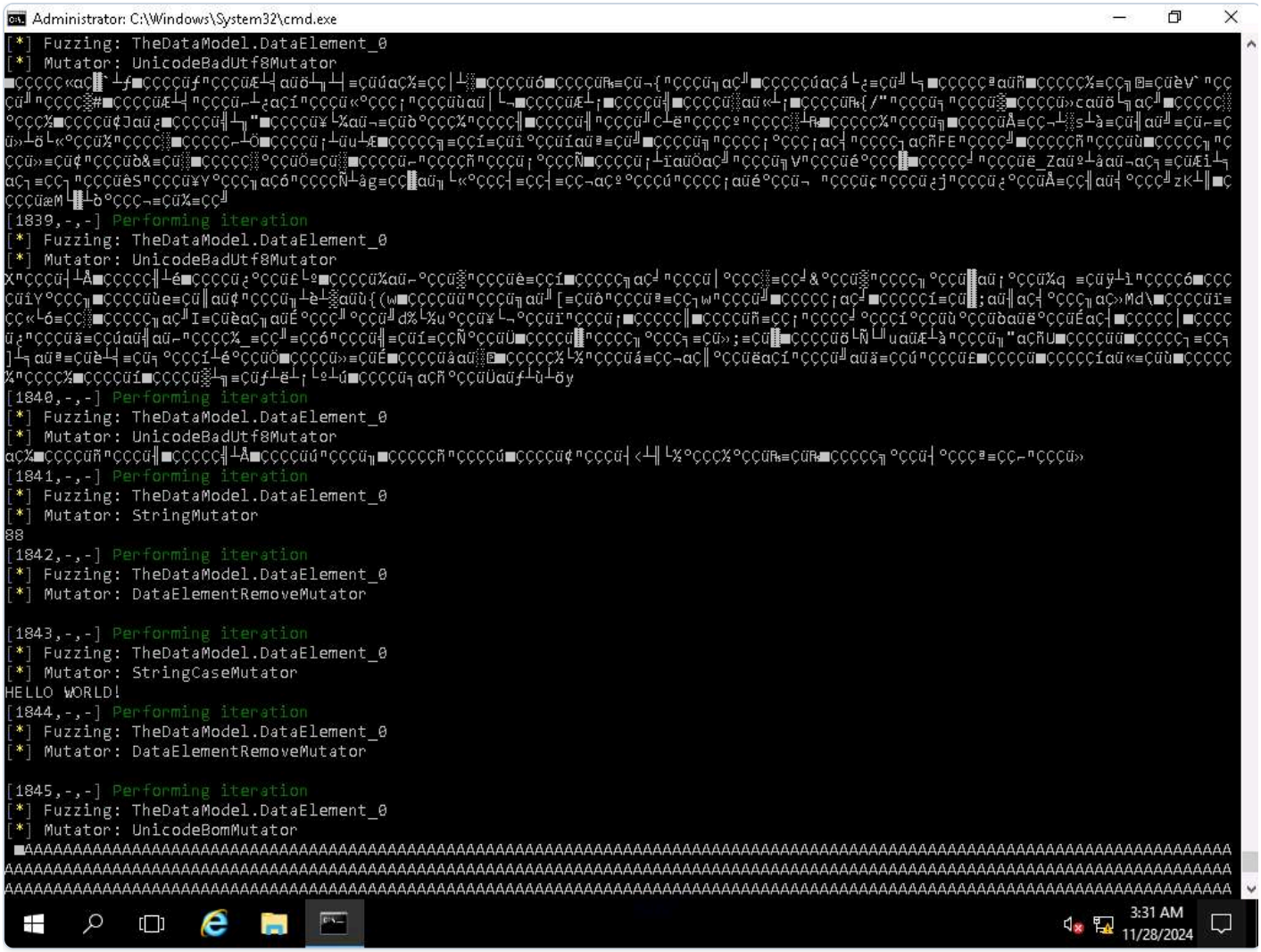
1. Review WinDbg path requirements in XML configuration files.

```
    <Param name="WinDbgPath" value="C:\Program Files (x86)\Windows Kits\10\Debuggers\x64" />
    <Param name="StartOnCall" value="ScoobySnacks"/>
</Monitor>
<Monitor class="PageHeap">
    <Param name="Executable" value="vlc.exe"/>
    <Param name="WinDbgPath" value="C:\Program Files (x86)\Windows Kits\10\Debuggers\x64" />
```

1. Inspect `status.txt` in `Logs\` directory tracking test iteration progress.



1. Inspect command-line iteration counter during execution.



1. Review mutator hint tags and element mutator properties (`mutable="false"`).

```
<Block name="Chunked-Body">
    <Block name="Chunk" minOccurs="0" maxOccurs="200" ref="Chunk-Tpl" />
    <String name="Last-Chunk" token="true" length="1" value="0">
        <Hint name="NumericalString" value="true" />
        <Hint name="ValidValues" value="0.1;0.00000001" />
    </String>
```

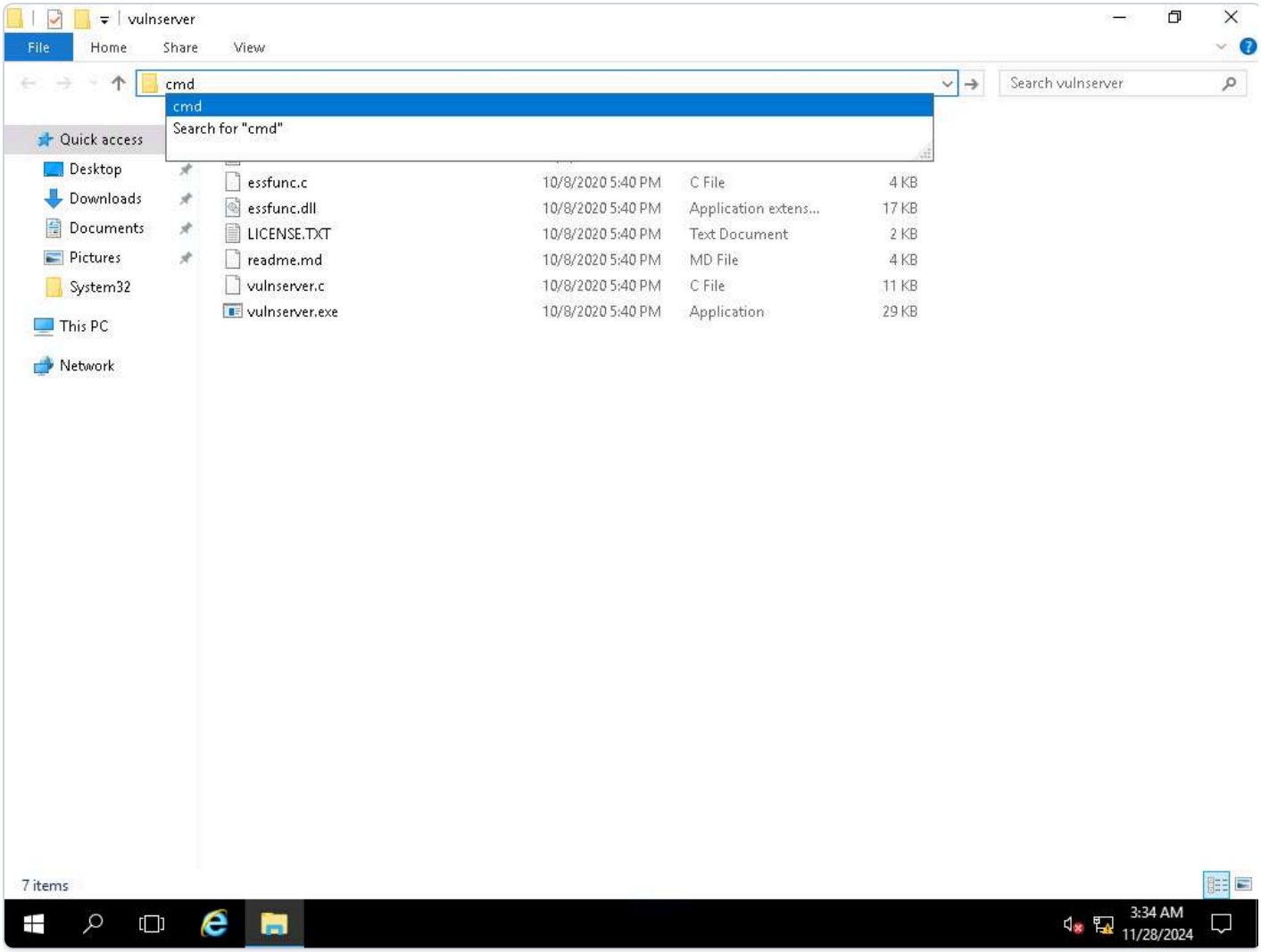
```
// SUPPORTED
//
0 references | dfmadrid, 4 days ago | 1 change
public new static bool supportedDataElement(DataElement obj)
{
    if (obj is Dom.Array && obj.isMutable)
        return true;

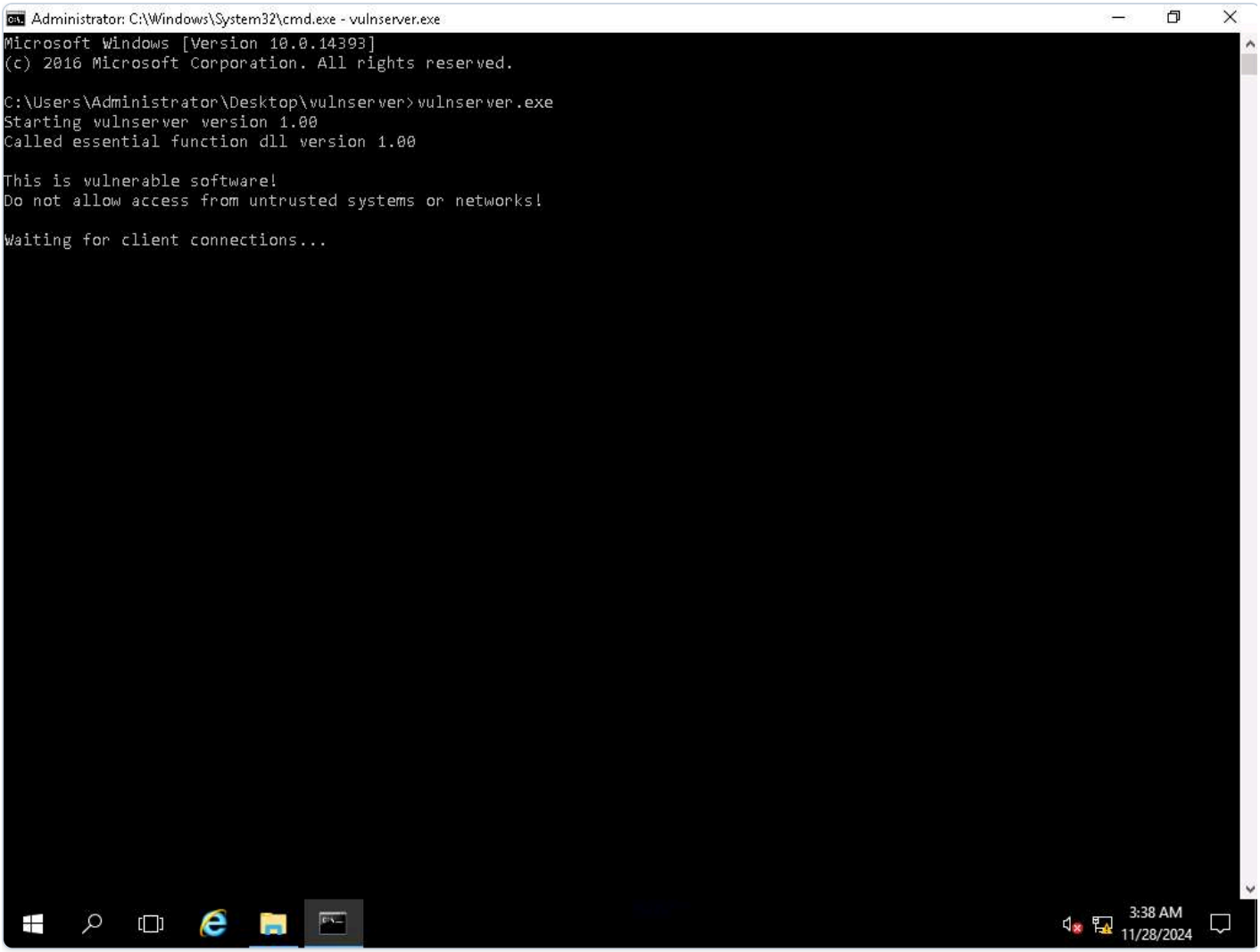
    return false;
}
```

1. Locate **vulnserver.exe** executable on Desktop.

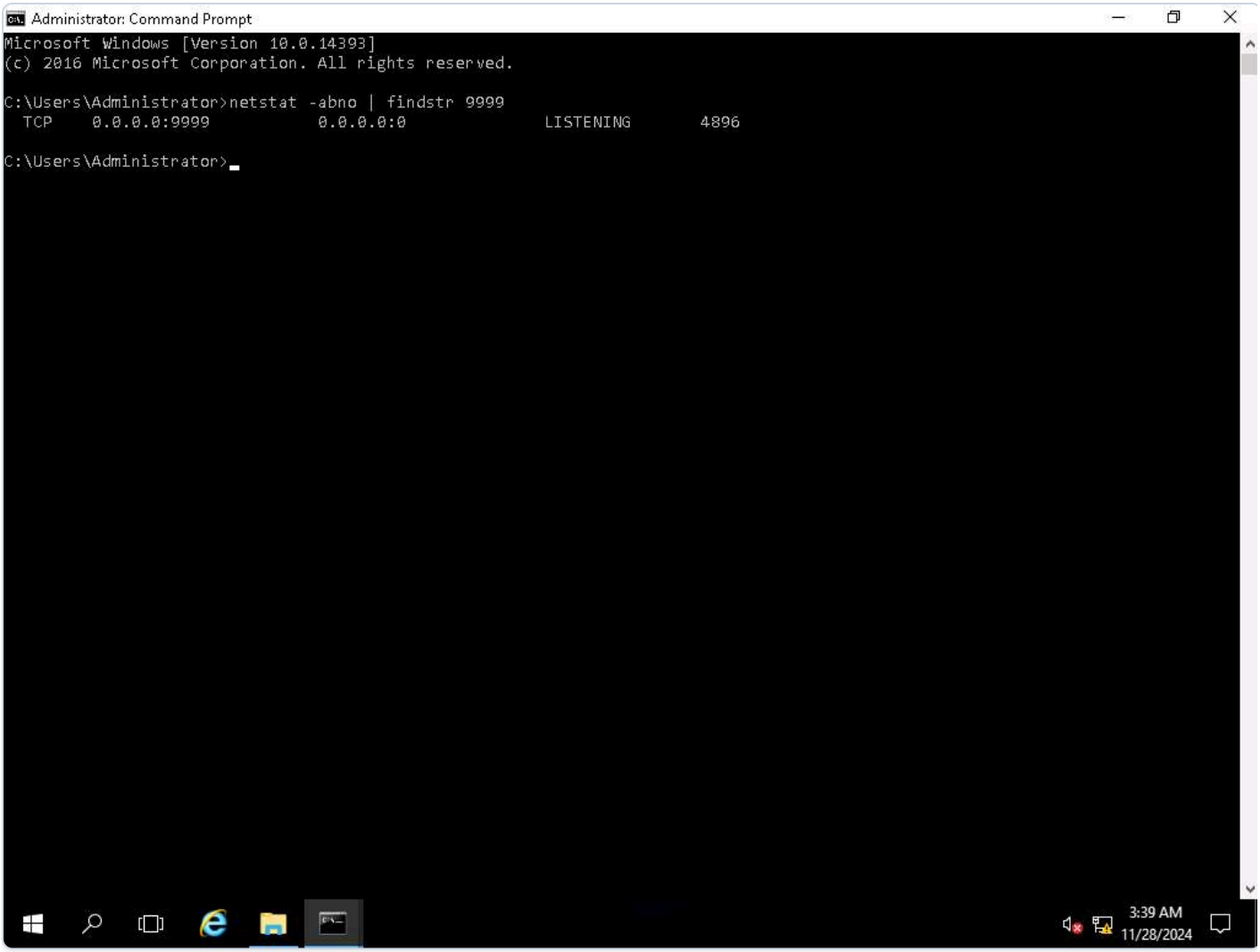


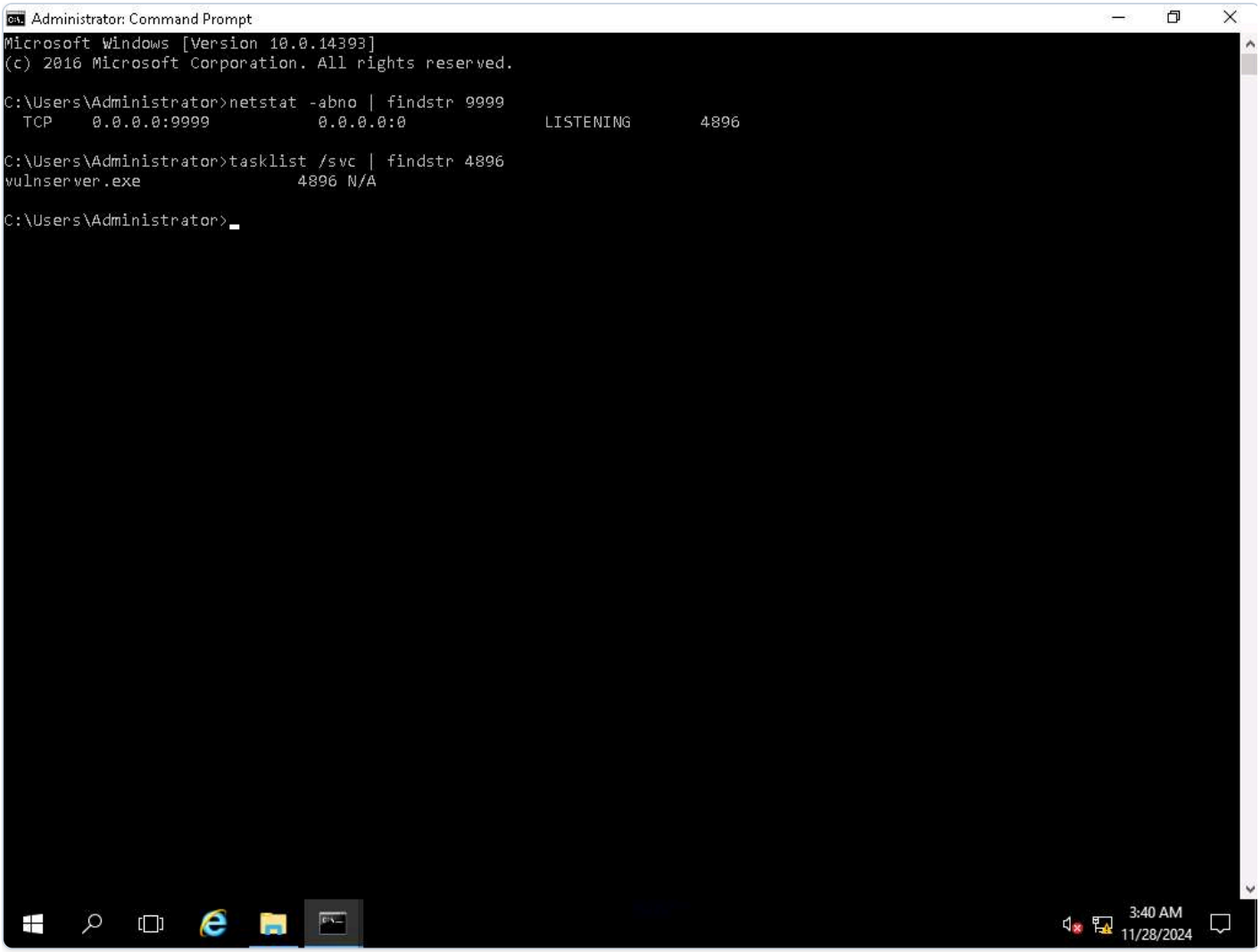
1. Open command line in `C:\Peach` and launch server binary:
   vulnserver.exe


vulnserver
File
Home
Share
View
cmd
cmd
Search for "cmd"
Search vulnserver
Quick access
Desktop
Downloads
Documents
Pictures
System32
This PC
Network
essfunc.c 10/8/2020 5:40 PM C File 4 KB
essfunc.dll 10/8/2020 5:40 PM Application extens... 17 KB
LICENSE.TXT 10/8/2020 5:40 PM Text Document 2 KB
readme.md 10/8/2020 5:40 PM MD File 4 KB
vulnserver.c 10/8/2020 5:40 PM C File 11 KB
vulnserver.exe 10/8/2020 5:40 PM Application 29 KB
7 items
3:34 AM
11/28/2024



1. Verify active listening port `9999` and correlate PID:
   netstat -abno | findstr 9999
   tasklist /svc | findstr

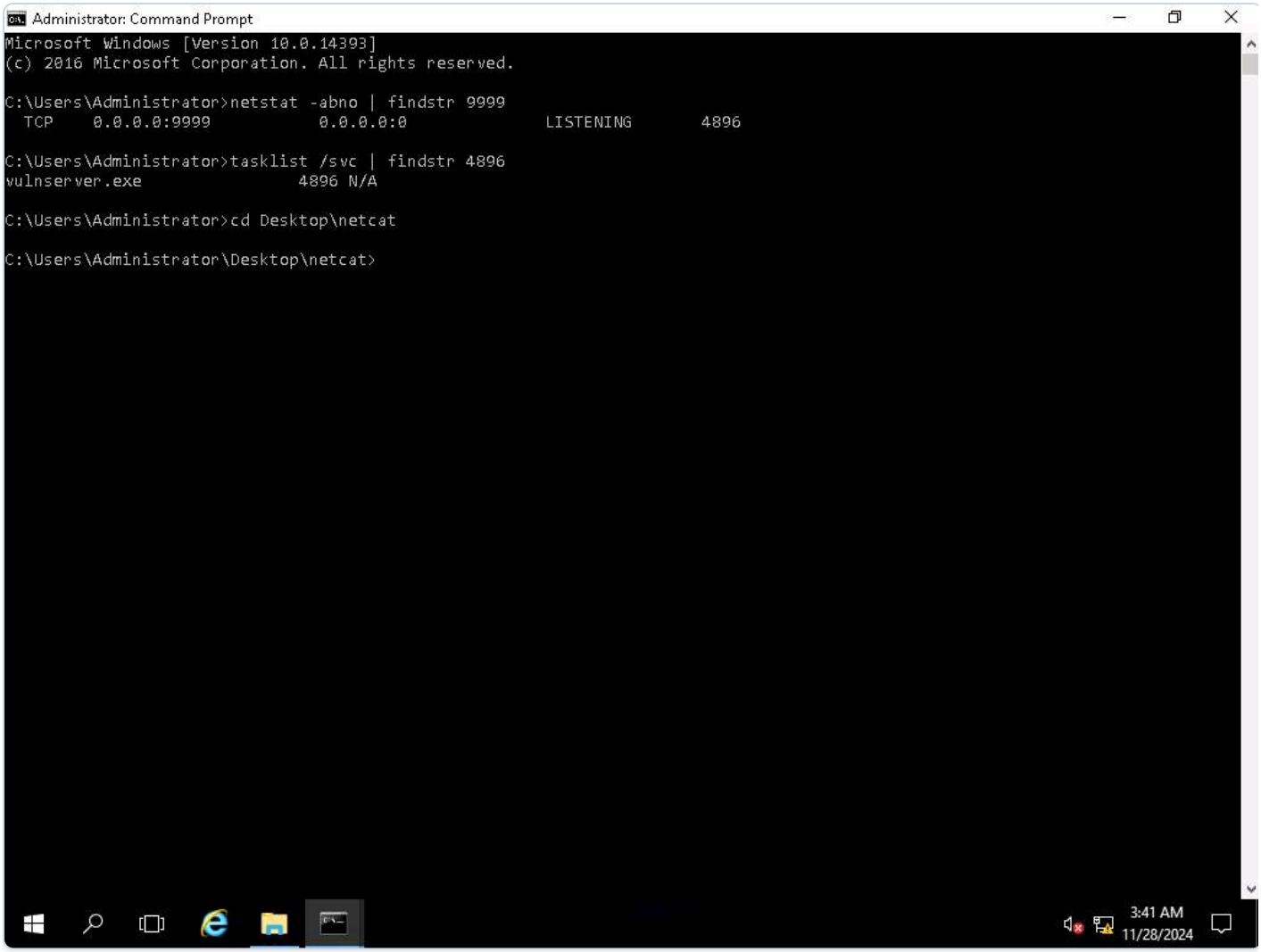

Administrator: Command Prompt
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.
C:\Users\Administrator>netstat -abno | findstr 9999
TCP 0.0.0.0:9999 0.0.0.0:0 LISTENING 4896
C:\Users\Administrator>
3:39 AM
11/28/2024

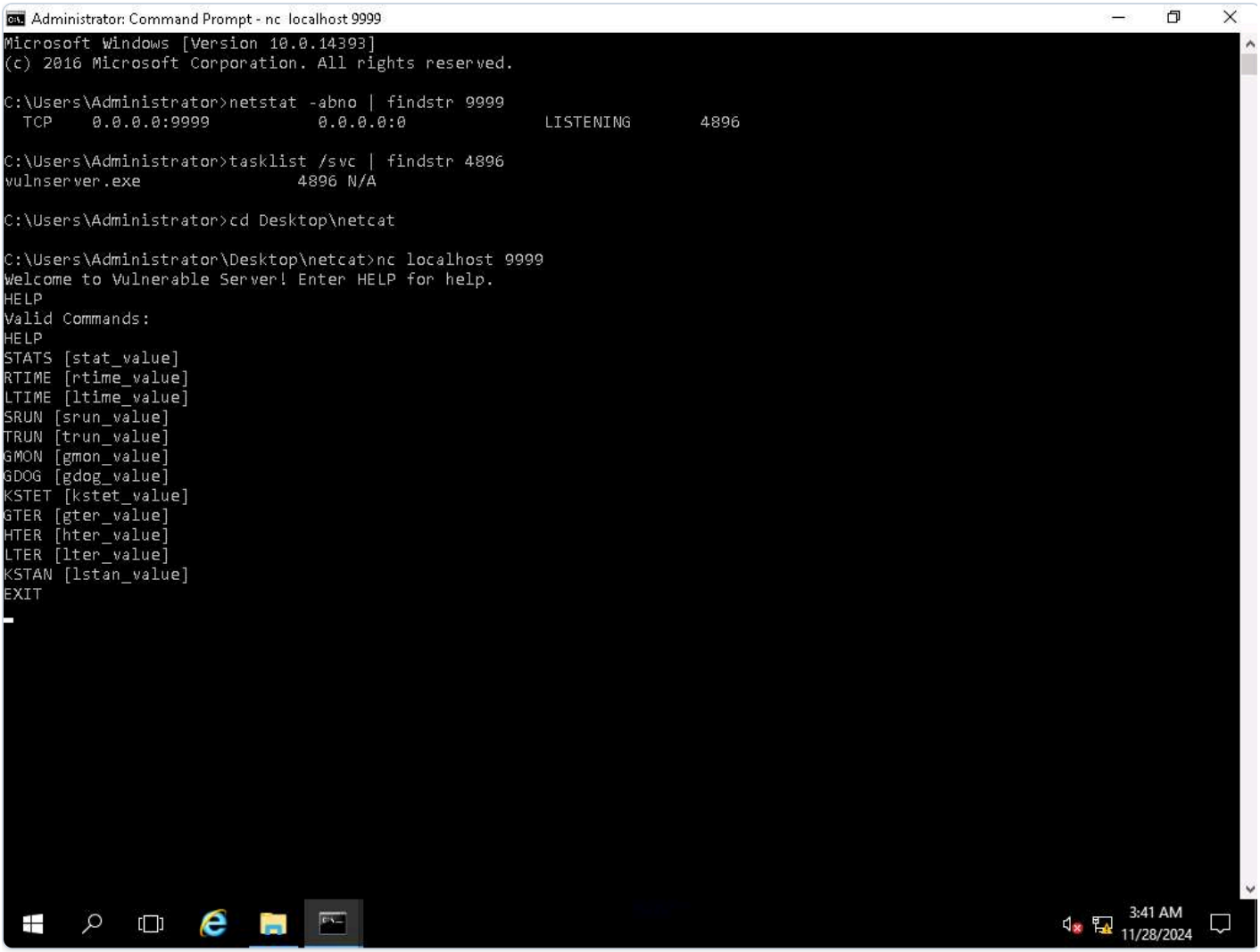


1. Test manual TCP connection via Netcat:

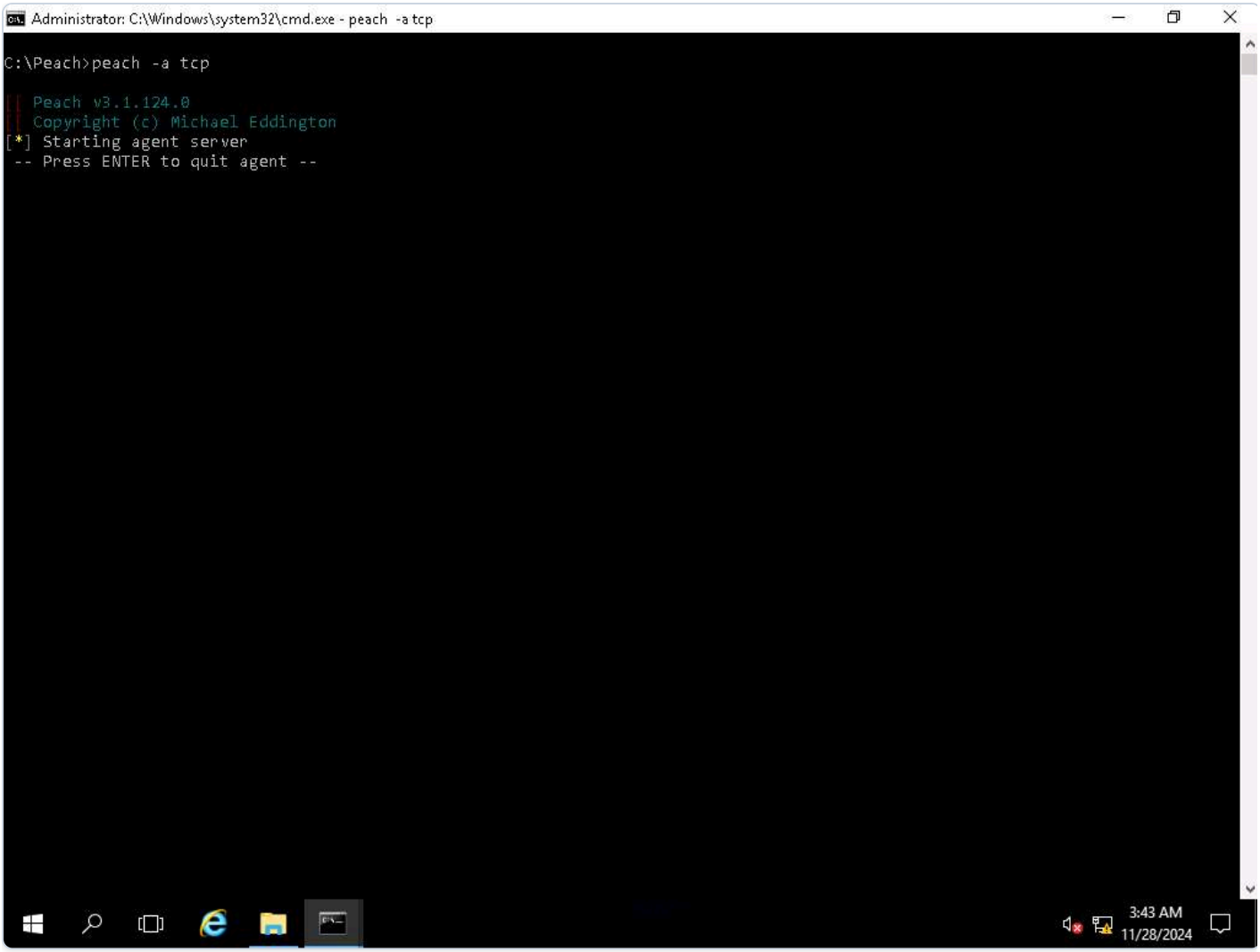
   cd Desktop\netcat

   nc localhost 9999

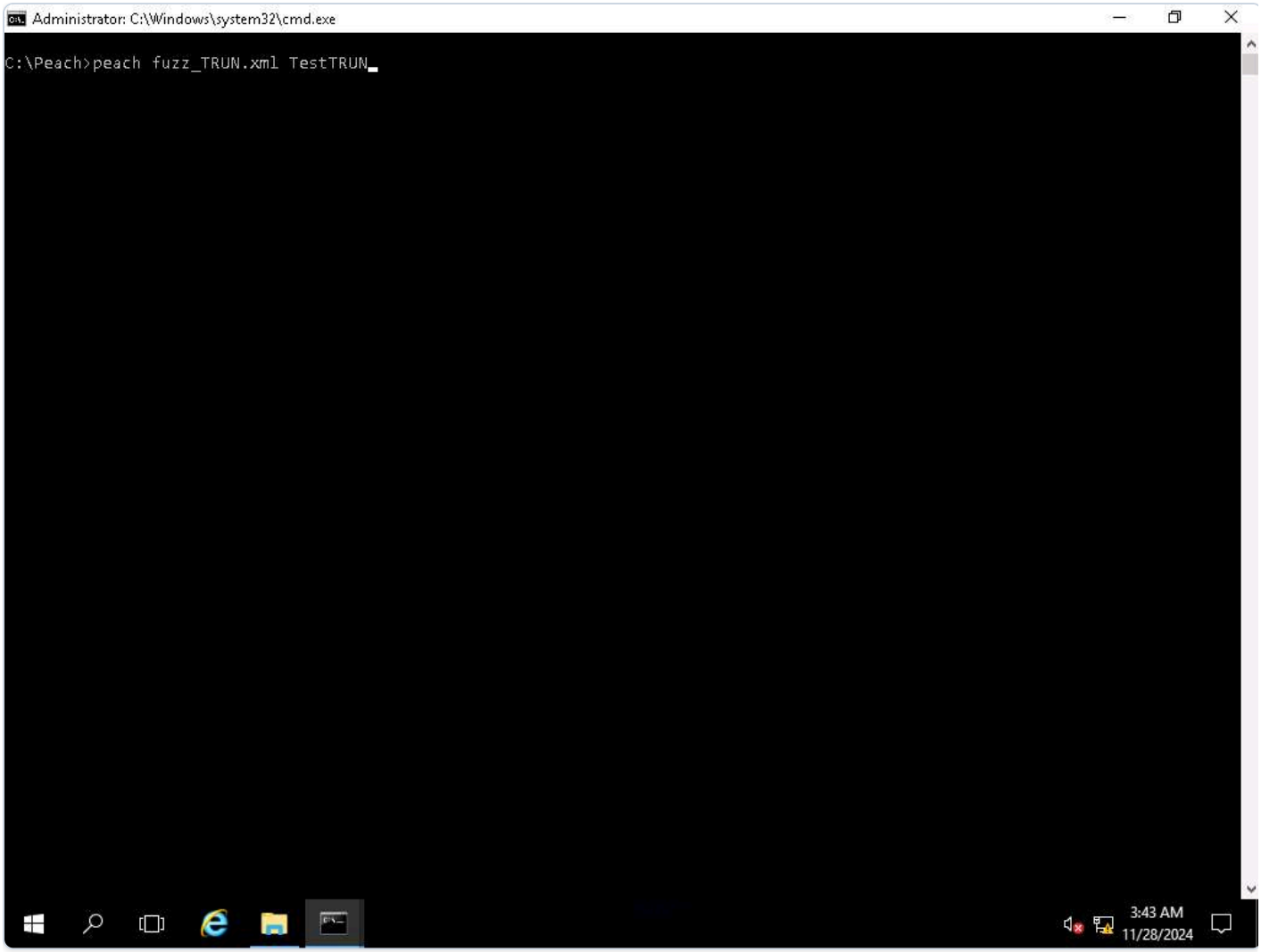

Administrator: Command Prompt
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.
C:\Users\Administrator>netstat -abno | findstr 9999
TCP 0.0.0.0:9999 0.0.0.0:0 LISTENING 4896
C:\Users\Administrator>tasklist /svc | findstr 4896
vulnserver.exe 4896 N/A
C:\Users\Administrator>cd Desktop\netcat
C:\Users\Administrator\Desktop\netcat>
3:41 AM
11/28/2024

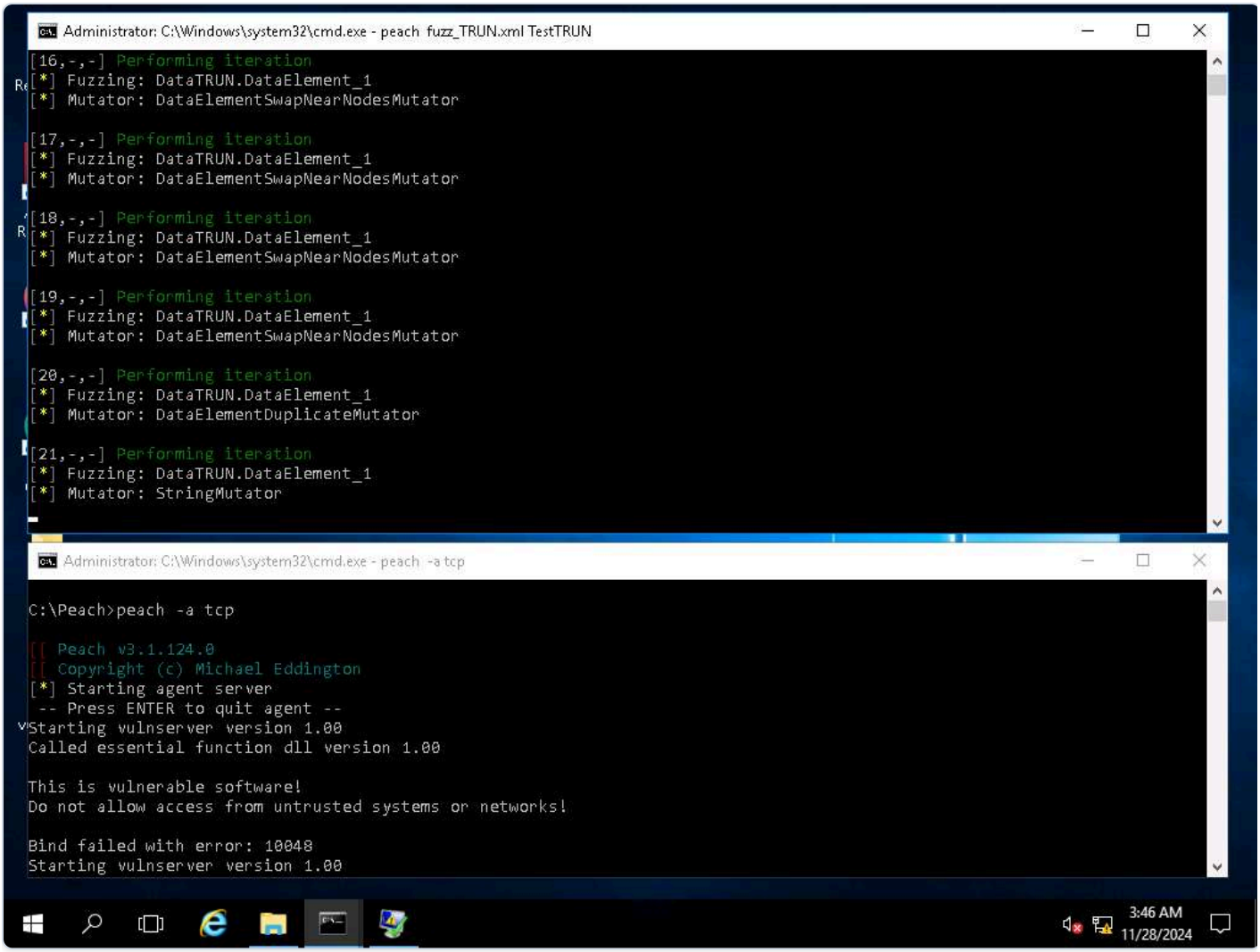


1. Open another terminal in `C:\Peach` and start Peach Agent:
   peach -a tcp

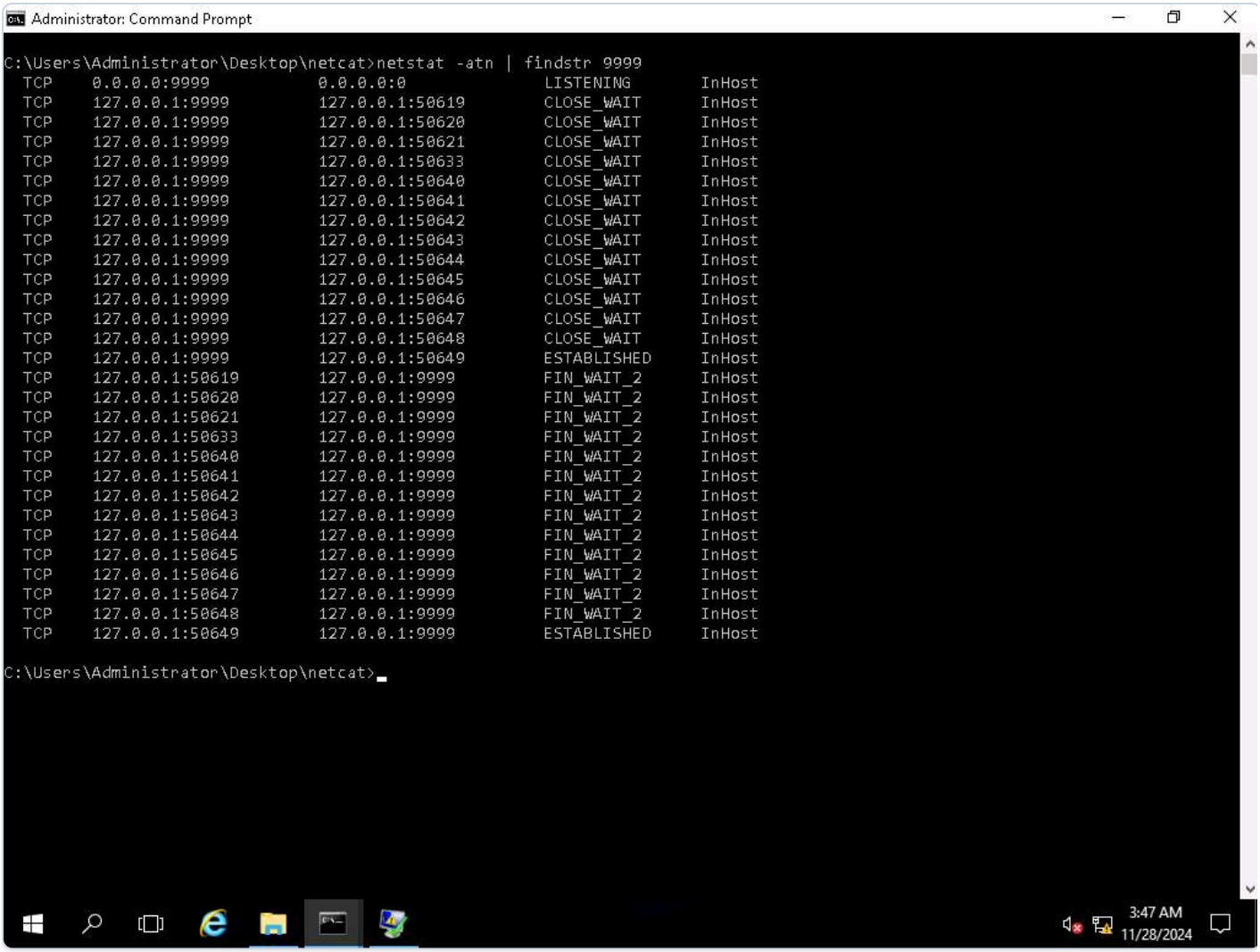


1. Switch to secondary Peach prompt and launch TRUN protocol fuzzing test:
   peach fuzz_TRUN.xml TestTRUN

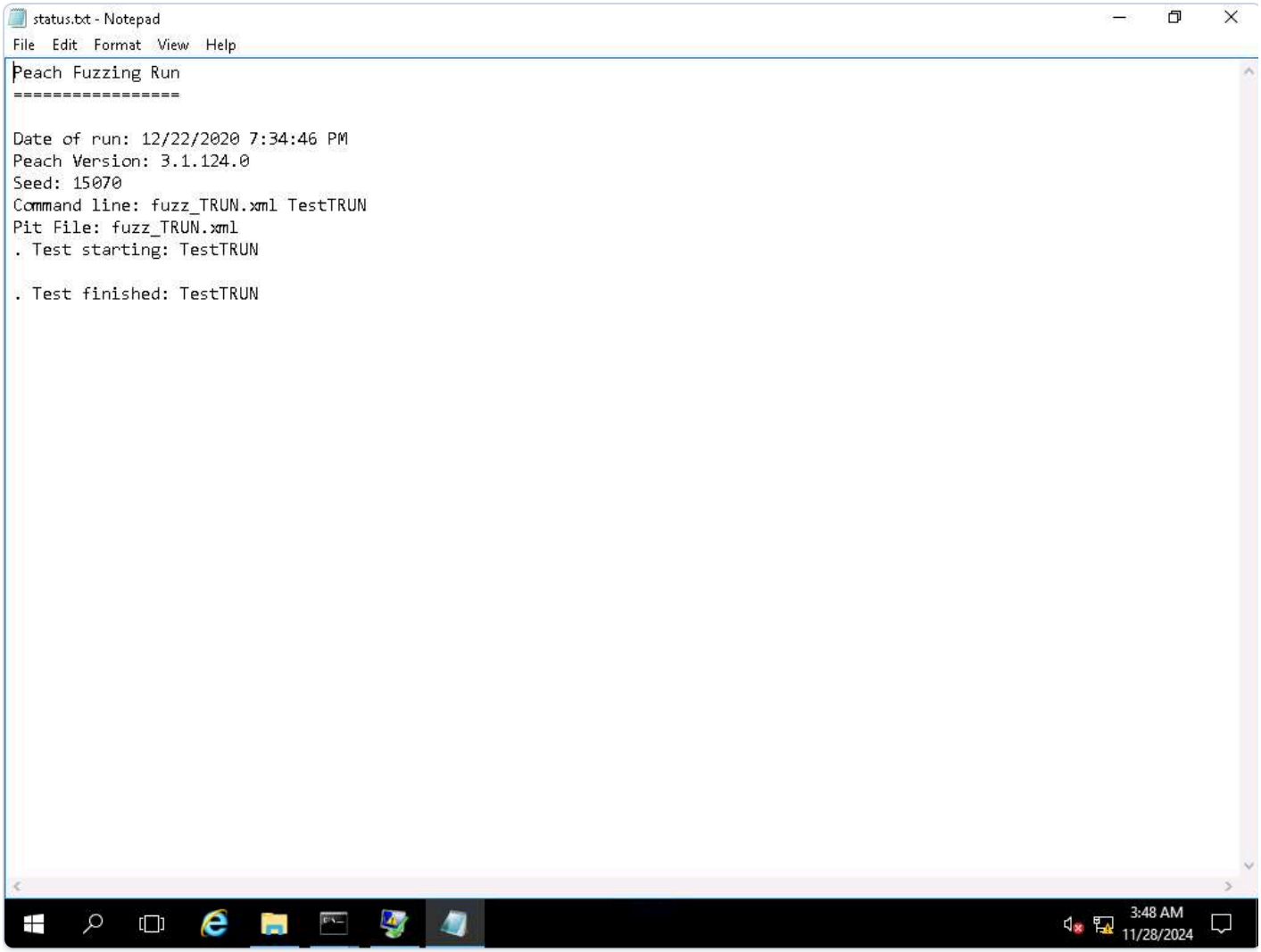

Administrator: C:\Windows\system32\cmd.exe
C:\Peach>peach fuzz_TRUN.xml TestTRUN
3:43 AM
11/28/2024



1. Monitor active TCP sockets on port `9999`:
   netstat -atn | findstr 9999



1. Inspect crash logging directory output and verify Peach version (**3.1.124.0**).



This concludes the lab exercise.

IMPORTANT: ❓ **Question 11.17.1.1** In Windows Server 2016 machine, use Peach fuzzer tool to perform fuzzing on vulnserver application. Enter the version of Peach installed in Windows Server 2016 machine. [!SUCCESS]
✅ **Answer:** **3.1.124.0**